

# **A Trusted Authorization Framework for Multi-Party Patient Consent in Healthcare Data Sharing**

## **CA2 Progress Report**

***Principi Supervisor: Professor Farookh Hussain***

***Co-Supervisor: Dr. Firas Al-Doghman***

***Presenter: Yasir Dhaifallah O Alyoubi***

***STUDENT ID #:24724078***

## Contents

|                                        |    |
|----------------------------------------|----|
| 1. Introduction.....                   | 3  |
| 2. Systematic Literature Review.....   | 4  |
| 3. Research Gaps & Questions.....      | 5  |
| 4. Research Objectives.....            | 6  |
| 5. Research Architecture: MVC.....     | 6  |
| 6. The Proposed Solution for RQ1.....  | 8  |
| 7. The Proposed Solution for RQ2.....  | 10 |
| 8. The Proposed Solution for RQ3.....  | 12 |
| 9. The Proposed Solution for RQ4.....  | 16 |
| 10. The Proposed Solution for RQ5..... | 16 |
| 11. The Proposed Solution for RQ6..... | 17 |
| 12. Publications Summary.....          | 20 |
| 13. Research Plan.....                 | 20 |

# **1. Introduction**

## **1.1 Research Context**

The rapid digitalisation of contemporary society has created an increasing demand for secure, interoperable, and trustworthy data sharing across organisational and institutional boundaries. Modern digital ecosystems frequently involve multiple independent stakeholders, including individuals, healthcare providers, service organisations, regulatory authorities, researchers, and third-party data processors, who may need to exchange information while maintaining privacy, accountability, and control over how that information is used [6, 19]. Although digital transformation creates significant opportunities for collaboration and service innovation, it also introduces a fundamental governance challenge: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain?

Healthcare represents a particularly important and challenging example of this broader problem. The increasing digitisation and decentralisation of healthcare information enables patients, healthcare professionals, guardians, researchers, healthcare organisations, and other authorised entities to participate in data-sharing processes [31, 14, 32]. At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control [24, 22, 12].

## **1.2 Problem Statement**

Existing consent-management and decentralised access-control approaches commonly represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created. The relationship between the consent record, the identity of the participants, their authority to act, the required authorisation conditions, the applicable policy constraints, and the resulting access decision is frequently treated as a collection of separate technical concerns.

This creates a fundamental distinction between consent representation and trustworthy authorisation enforcement. A consent record can demonstrate that a decision has been created or recorded, but it does not necessarily establish why that decision should be trusted when it is subsequently exercised. Immutability protects the integrity of recorded information, but immutability alone does not verify the legitimacy of the entities that participated in the decision. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information.

## **1.3 Research Motivation**

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and

enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied.

The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object that connects the relevant participants, authority requirements, policy constraints, and evidence associated with an authorisation decision. This conceptualisation makes it possible to evaluate the relationship between the consent itself and a subsequent data-access request rather than assuming that the existence of a recorded consent automatically justifies future access.

## **2. Systematic Literature Review**

### **2.1 Overview and Methodology**

The systematic literature review examines the current state of research on trustworthy and decentralised data sharing, with particular attention to healthcare consent management, multi-party trust data governance, decentralised identity, verifiable credentials, multi-party authorisation, policy-based access control, and Trusted Computing. The objective of the review is not simply to identify technologies that can be applied to healthcare data sharing, but to examine how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain.

The reviewed literature demonstrates that substantial progress has been made in individual areas. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing [31, 14, 24, 22, 12]. Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management [2, 7, 3, 30, 26]. Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication [20, 33, 4, 16, 5, 27]. Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information [32, 11, 28, 25].

### **2.2 Synthesis of Findings**

The reviewed literature demonstrates that existing approaches provide strong solutions for individual dimensions of trustworthy data sharing. Blockchain-based systems provide tamper-resistant recording and auditability; DID and VC mechanisms provide decentralised identity and verifiable attributes; policy-based and cryptographic access-control mechanisms provide fine-grained data protection; collaborative governance mechanisms support distributed participation; and Trusted Computing provides secure execution and attestation capabilities.

However, these contributions address different layers of the security problem. No individual mechanism can independently establish that a healthcare data-access

decision is trustworthy. A blockchain record does not establish participant authority, a valid DID does not establish access permission, multi-party participation does not guarantee policy compliance, and secure execution does not guarantee that the underlying authorisation policy is correct.

## 2.3 Gap Identified in the Literature

The literature review identifies a consistent pattern of fragmentation across existing research. Blockchain-based approaches primarily address the integrity and traceability of recorded events. Decentralised identity and verifiable credential systems address the identification and attribute verification of participating entities. Multi-party governance mechanisms address distributed participation and collective decision-making. Policy-based access-control approaches determine whether requested operations comply with predefined constraints. Trusted Computing technologies protect the execution of security-sensitive computation.

These mechanisms provide important but incomplete answers when considered independently. The existence of a valid blockchain record does not guarantee that the authorisation decision was generated by legitimate and appropriately authorised participants. A verified identity does not imply permission to access a specific patient's information. A valid credential does not necessarily satisfy a multi-party approval requirement. Similarly, sufficient approvals do not guarantee that a subsequent request remains within the authorised purpose or healthcare data scope.

## 3. Research Gaps & Questions

### 3.1 Research Gaps

The central research gap therefore concerns the absence of a sufficiently integrated Trust Computing framework that explicitly models the relationship between these independently verifiable conditions. In particular, existing approaches provide limited treatment of patient consent as a security-bearing and policy-aware authorisation object whose validity depends on coordinated conditions concerning participant identity, authority, collective approval, and contextual policy compliance.

### 3.2 Main Research Question

How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?

### 3.3 Sub-Research Questions

- **SRQ1:** How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?
- **SRQ2:** How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?
- **SRQ3:** How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?

- **SRQ4:** How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?
- **SRQ5:** How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?
- **SRQ6:** How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

## 4. Research Objectives

- **R01 — Trust-Centric Consent Model:** The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model will incorporate identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.
- **R02 — Decentralised Identity and Authority Trust:** The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.
- **R03 — Trustworthy Multi-Party Authorisation:** The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants can jointly establish a trustworthy consent decision.
- **R04 — Policy- and Context-Aware Access Control:** The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.
- **R05 — Temporal and Lifecycle Trust:** The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.
- **R06 — Formal Security Assurance and Empirical Validation:** The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.

## 5. Research Architecture: MVC

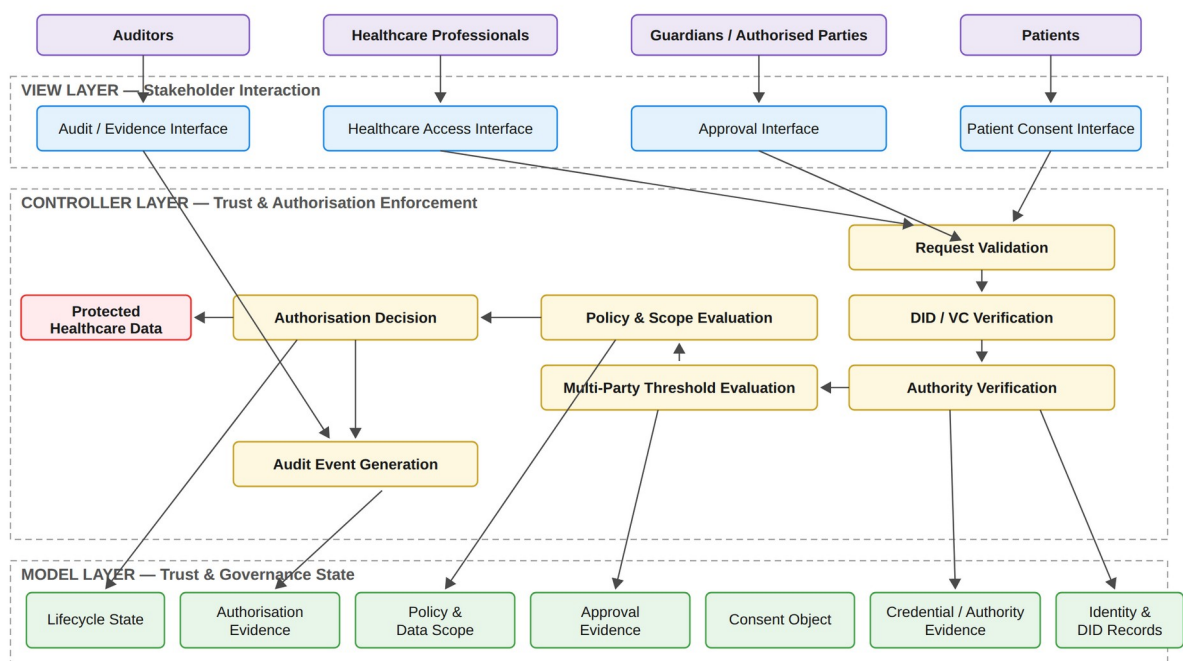
The proposed HALAH framework adopts a layered Model-View-Controller (MVC) architecture to provide a clear separation between consent representation, stakeholder interaction, and security-critical authorisation enforcement. The purpose

of this architectural decomposition is not simply to follow a conventional software engineering pattern, but to establish explicit boundaries between the information that represents trust, the interfaces through which participants express their actions, and the mechanisms that determine whether those actions should result in an authorisation decision.

At the highest level, the architecture consists of three complementary layers: the View Layer, the Controller Layer, and the Model Layer. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Sensitive healthcare data are treated as protected resources whose access is mediated by the Controller rather than directly exposed to the View.

The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include request validation, decentralised identity verification, credential and authority verification, multi-party approval evaluation, policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed.

The Model Layer maintains the persistent security and governance state required by these evaluations. It includes identity and DID information, credential and authority evidence, consent objects, approval evidence, policy and data-scope constraints, authorisation evidence, and lifecycle state. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted.



Protected healthcare data is positioned outside the three layers; every sensitive operation passes through the Controller.

Figure 3: Layered MVC Architecture and Component Decomposition of the HALAH Framework

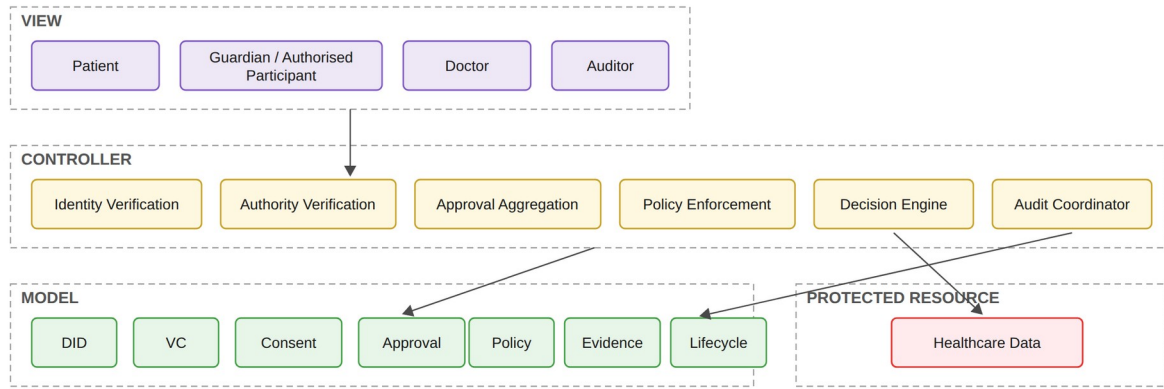


Figure 4: Functional Decomposition of the MVC Components

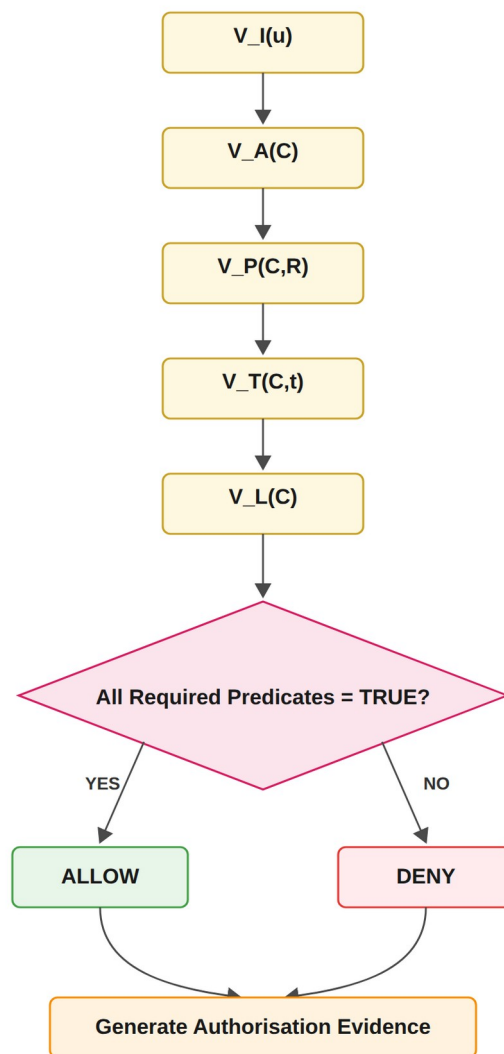


Figure 5: Trust Predicate Evaluation and Authorisation Decision Flow

## 6. The Proposed Solution for RQ1

Status: **Done**

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions access may be granted. The proposed consent object is represented as

$$C = (I, A, P, E)$$

where I represents patient and participant identity information, A represents authorisation requirements, P represents policy constraints, and E represents authorisation evidence. The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit.

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. This distinction is important because the research treats consent as a structured policy-bound object rather than as a simple Boolean permission.

The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I, RO3 evaluates the authorisation requirements contained in A, and RO4 evaluates the policy constraints contained in P. Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

---

**Algorithm 1** Trust-Aware Consent Creation

---

**Require:** Patient identity  $I_p$ , authorised doctor D, guardian set G, purpose  $P_u$ , data scope  $S_c$ , validity interval T

**Ensure:** Consent object C or rejection

- 1: Validate  $I_p$
  - 2: **if**  $I_p$  is invalid **then**
    - 3: **return** REJECT
  - 4: **end if**
  - 5: Validate authorised doctor D
  - 6: Validate guardian set G
  - 7: Validate purpose  $P_u$
  - 8: Validate data scope  $S_c$
  - 9: Validate validity interval  $T = (t_s, t_e)$
  - 10: **if**  $t_e \leq t_s$  **then**
    - 11: **return** REJECT
  - 12: **end if**
  - 13: Define authorisation requirement A
  - 14: Generate consent identifier  $id_c$
  - 15: Construct  $C = (I, A, P, E)$
  - 16: Persist C
  - 17: Record consent creation evidence
  - 18: **return** C
-

*The patient subsystem after consent creation: four EMR modules, two designated guardians, jurisdiction AU, and the state PENDING\_SIGNATURE.*

The subsystem requires the patient to specify the Patient DID, Authorised Doctor DID, Data Access Scope, Designated Guardian DIDs, the Jurisdiction, and the temporal validity of the consent. These fields collectively operationalise the proposed consent representation.

Finally, the Start Time and Expiry Time implement temporal constraints on the consent, and the Jurisdiction field records the legal territory (AU in the demonstrated transaction). Consequently, authorisation is not represented as a permanent or universal permission. Instead, the consent has a defined lifecycle and territory and can subsequently be evaluated by the Consent Engine according to both. At this point the consent exists only in the application ledger, in the state PENDING\_SIGNATURE; nothing is written to the blockchain until the guardians have approved.

## 7. The Proposed Solution for RQ2

### Status: Done

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.

*Identity  $\neq$  Authorisation.*

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should automatically grant access to patient data. Instead, the verified

identity and authority information become inputs to the subsequent authorisation process.

$$Identity(u) \wedge CredentialValidity(u) \wedge Authority(u, C) \Rightarrow V_I(u) = VALID.$$

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance.

This mechanism contributes to the trust-oriented framework by converting identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4.

---

#### Algorithm 2 DID and VC Identity and Authority Verification

---

**Require:** Participant  $u$ , consent object  $C$

**Ensure:** Verification result  $V_I(u)$

- 1: Resolve DID of  $u$
  - 2: **if** DID resolution fails **then**
    - 3: **return** INVALID
  - 4: **end if**
  - 5: Verify DID document and associated identity information
  - 6: **if** DID verification fails **then**
    - 7: **return** INVALID
  - 8: **end if**
  - 9: Retrieve VC associated with  $u$
  - 10: **if** VC retrieval fails **then**
    - 11: **return** INVALID
  - 12: **end if**
  - 13: Verify VC signature, issuer, subject, and validity
  - 14: **if** VC verification fails **then**
    - 15: **return** INVALID
  - 16: **end if**
  - 17: Extract role and authority claims from VC
  - 18: **if** claims do not satisfy the authority requirements of  $C$  **then**
    - 19: **return** INVALID
  - 20: **end if**
  - 21: Record identity and authority verification evidence
  - 22: **return** VALID
- 

*The guardian subsystem at the first approval: the EIP-712 signature of did:parent:A is verified and the multi-signature count is 1/2.*

As shown in the figure above, the first guardian (did:parent:A) approves the consent and the subsystem reports EIP-712 signature verified (signer 0x3Af549b0...) with the multi-signature count 1/2. The consent remains pending, because the approval condition has not yet been satisfied. The second guardian then repeats the same procedure.

As shown in the figure above, the guardian first enters the target Consent ID, after which the system retrieves the corresponding active transaction and displays the associated patient DID. The guardian then selects their own Guardian DID identity and approves the consent with an EIP-712 typed-data signature, which binds the approval to this specific consent, this guardian and this network (chainId 11155111). The system verifies each signature by recovering the signer address and comparing it with the address associated with that guardian DID. A signature produced for another consent, another guardian or another chain is rejected, and the interface refuses a second signature from the same guardian.

## 8. The Proposed Solution for RQ3

**Status:** Done

RO3 addresses RQ3 by developing a threshold-based multi-party authorisation mechanism. The objective is to ensure that sensitive healthcare data cannot be accessed through unilateral approval when the consent requires participation from multiple independently verified parties. Let  $A_v$  denote the set of valid approvals and let  $N$  denote the required authorisation threshold. The threshold condition is defined as

$$V_A(C) = 1, |A_v| \geq N; 0, |A_v| < N.$$

Algorithm 3 explicitly distinguishes between invalid, duplicate, and valid approvals. This distinction is important because simply counting submitted signatures could incorrectly treat unauthorised or repeated approvals as independent evidence.

This mechanism complements the DID/VC verification procedure in Algorithm 2. Algorithm 2 establishes whether an individual participant possesses a valid identity and sufficient authority, whereas Algorithm 3 determines whether a sufficient number of independently verified participants have collectively satisfied the consent-defined authorisation requirement. The resulting activation evidence can subsequently be consumed by the policy and scope enforcement layer before healthcare data are released.

---

### Algorithm 3 Threshold-Based Multi-Party Authorisation

---

**Require:** Consent object  $C$ , participant approval  $a$ , threshold  $N$

**Ensure:** Authorisation result

- 1: Retrieve required participant set  $G$
- 2: Verify identity and authority of participant submitting  $a$
- 3: **if** verification fails **then**
  - 4: Record invalid approval
  - 5: **return** DENY
- 6: **end if**
- 7: **if** participant is not in  $G$  **then**
  - 8: Record unauthorised approval attempt
  - 9: **return** DENY

```
10: end if
11: if participant has already approved C then
12:   Record duplicate approval
13: return DENY
14: end if
15: Record valid approval a
16: Update valid approval set  $A_v$ 
17: if  $|A_v| \geq N$  then
18:   Activate authorisation
19:   Generate activation or token evidence
20:   Record threshold-satisfied event
21: return ALLOW
22: else
23:   Keep consent in pending state
24:   Record threshold-pending event
25: return PENDING
26: end if
```

---

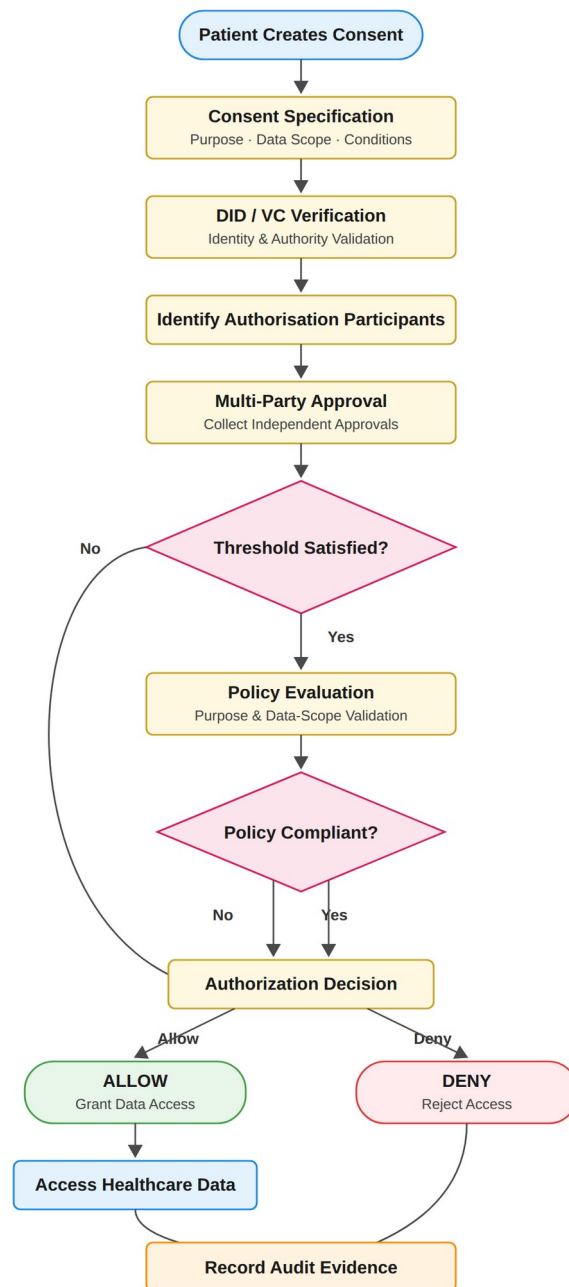


Figure 6: End-to-End Workflow of Trust-Oriented Consent Authorization Framework

**Guardian Cryptographic Approval**

Enter Target Consent ID

04da25f5-b16f-4d9a-af39-a78f0a83b17f

Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a

Select Your Guardian DID Identity

did:parent:B

Sign Consent via VC

EIP-712 signature verified (signer 0x39B12b87...), Multi-sig: 2/2

[SBT MINTED - LOCAL LEDGER]

- \* Soulbound Token ID: SBT-LOCAL-04da25f5
- \* Status: 2/2 guardian approval reached - on-chain anchoring result shown below.

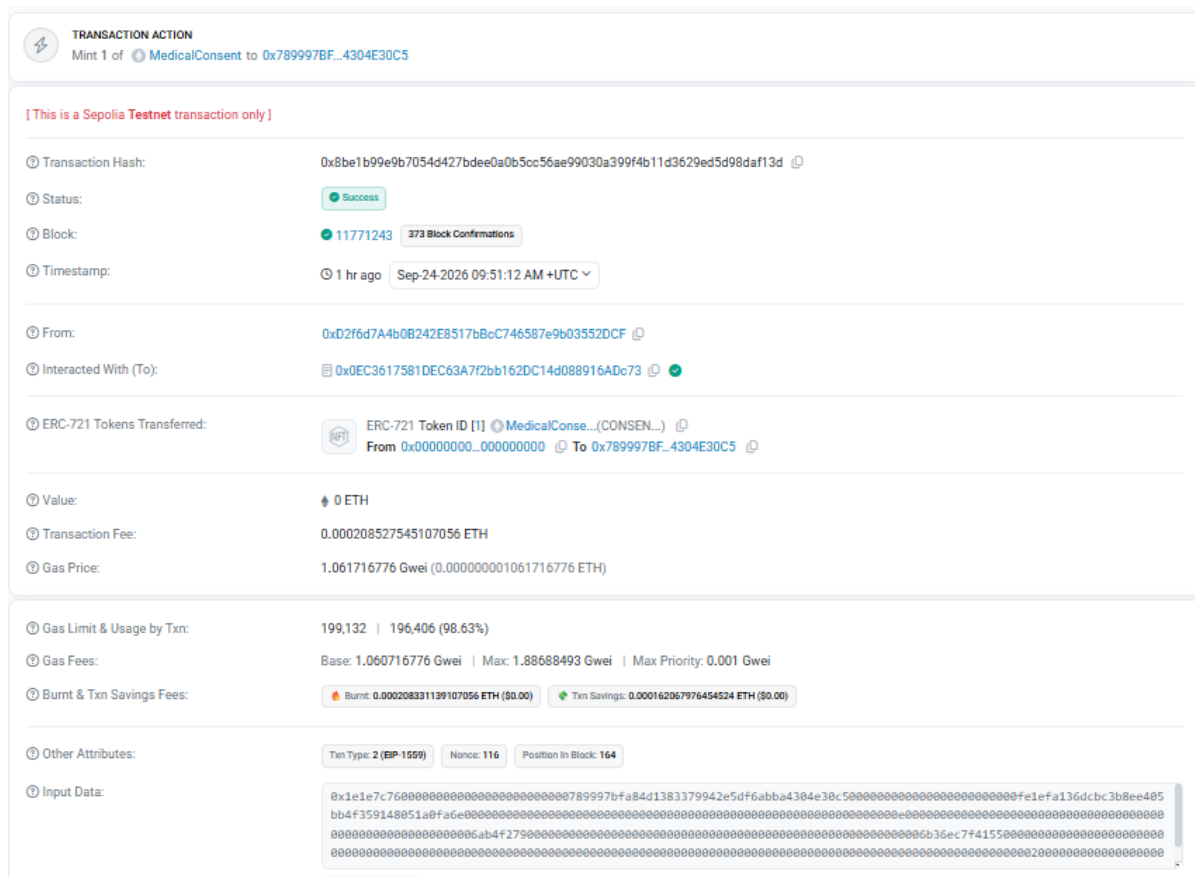
Anchoring on Sepolia in the background (15-30 s). You may navigate away - the result is written to the ledger automatically. Refresh or open Auditor to see it.

*The guardian subsystem at the moment of the second approval: the EIP-712 signature is verified, the 2/2 threshold is reached, the SBT is minted in the local ledger and the Sepolia anchoring starts in the background.*

For the demonstrated two-guardian configuration, the approval process can also be represented as:

$$\sum_{g \in G} \text{Sign}(g, C) \geq |G| = 2$$

where  $G$  represents the designated guardians and every listed guardian must provide a valid signature for activation. Once the required signatures have been obtained, the subsystem displays SBT MINTED together with the Soulbound Token identifier, and a background job submits the mint transaction to Sepolia. While the background job is running, the subsystem reports the intermediate state explicitly.



*The anchoring transaction of the evaluated consent on Sepolia Etherscan: status Success, block 11,771,243, 'Mint 1 of MedicalConsent' to the pseudonymous patient address (function selector 0x1e1e7c76, mintConsentV3).*

As shown in the figure above, the anchoring of the evaluated consent (token #1) is an ordinary, publicly verifiable transaction: Etherscan reports the status Success, the block number 11,771,243, the transaction fee, and the transfer of one MedicalConsent token to the pseudonymous patient address derived from the patient DID. The transaction can be inspected at [Etherscan: mint transaction](<https://sepolia.etherscan.io/tx/0x8be1b99e9b7054d427bdee0a0b5cc56ae99030a399f4b11d3629ed5d98daf13d>). This provides an implementation-level demonstration that consent activation can be verified independently of the application.

## 9. The Proposed Solution for RQ4

### Status: In Progress

The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. Accordingly, the mechanism will evaluate whether the requested purpose is consistent with the consent and whether the requested data scope is contained within the permitted scope.

In the current prototype, the policy dimension of RO4 is already exercised operationally: every access request is evaluated against the authorised data scope, the temporal validity window, and the jurisdiction recorded in the consent, and the doctor subsystem refuses an out-of-jurisdiction request with an explicit listing of the

failed checks. The full policy-language enforcement layer remains the objective of the next stage.

Enter Authorised Consent ID

f050c29a-3d92-4131-8605-63bcb1ff8d92

### Consent Information

Patient  
**did:pat...**

Consent ID  
**f050c2...**

Purpose  
**Treat...**

Requester jurisdiction (VL check)

SA

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

|      |      |      |      |      |       |
|------|------|------|------|------|-------|
| VI   | VA   | VP   | VT   | VL   | ALLOW |
| PASS | PASS | PASS | PASS | FAIL | FAIL  |

Consent State: ACTIVE

*The doctor subsystem with requester jurisdiction SA: VL reports FAIL and consequently ALLOW = FAIL, although the consent state remains ACTIVE.*

## 10. The Proposed Solution for RQ5

### Status: In Progress

The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. It will investigate how temporal and lifecycle conditions can be incorporated into the authorisation decision without weakening the trust relationships established by the current stage mechanisms.

The lifecycle dimension of RO5 is partially demonstrated in the current prototype: every consent progresses through the controlled states PENDING\_SIGNATURE, PENDING\_TOKEN, ACTIVE and REVOKED, and revocation is executed as a real Sepolia transaction (block 11,771,307), after which the doctor's authorisation check  $V_A$  fails and access is refused. The formal lifecycle-trust model and expiry-driven transitions remain next-stage work.

### My Consents

|                                   |                   |                                          |                         |
|-----------------------------------|-------------------|------------------------------------------|-------------------------|
| 2502632b... →<br>did:hospital:001 | REVOKED           | 0/2 sigs - token: -                      | REVOKED                 |
| aca837a1... →<br>did:hospital:001 | REVOKED           | 0/2 sigs - token: -                      | REVOKED                 |
| cd9a24bd... →<br>did:hospital:001 | REVOKED           | 2/2 sigs - token: SBT-LOCAL-<br>cd9a24bd | REVOKED                 |
| 011bbb21... →<br>did:hospital:001 | REVOKED           | 2/2 sigs - token: SBT-8                  | REVOKED                 |
| 0975c645... →<br>did:hospital:001 | PENDING_SIGNATURE | 0/2 sigs - token: -                      | <button>Revoke</button> |
| f050c29a... →<br>did:hospital:001 | REVOKED           | 2/2 sigs - token: SBT-1                  | REVOKED                 |

*The patient subsystem after revocation: the evaluated consent is REVOKED together with its on-chain token number.*

## 11. The Proposed Solution for RQ6

**Status: Partially completed (for RQ1, RQ2, RQ3)**

Enter Authorised Consent ID

f050c29a-3d92-4131-8605-63bcb1ff8d92

### Consent Information

Patient  
**did:pat...**

Consent ID  
**f050c2...**

Purpose  
**Treat...**

Requester jurisdiction (VL check)

AU

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

|      |      |      |      |      |       |
|------|------|------|------|------|-------|
| VI   | VA   | VP   | VT   | VL   | ALLOW |
| PASS | PASS | PASS | PASS | PASS | PASS  |

●

Consent State: ACTIVE

*The doctor subsystem with requester jurisdiction AU: the decision matrix reports PASS on every evaluated check, ALLOW = PASS, and the consent state is ACTIVE.*

As shown in the figure above, the five checks VI (identity), VA (authorisation), VP (purpose), VT (time) and VL (jurisdiction) all report PASS, and consequently ALLOW = PASS. The subsystem then presents the Authorised Data Scope, showing that only the EMR modules specified in the original consent are available.

Patient

did:patient:5f01f...

Consent ID

04da25f5-b16f-4...

Purpose

Treatment

Requester jurisdiction (VL check)

AU

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | PASS | PASS | PASS | PASS | PASS  |

Consent State: ACTIVE

Authorised Medical Records

OBSERVATION

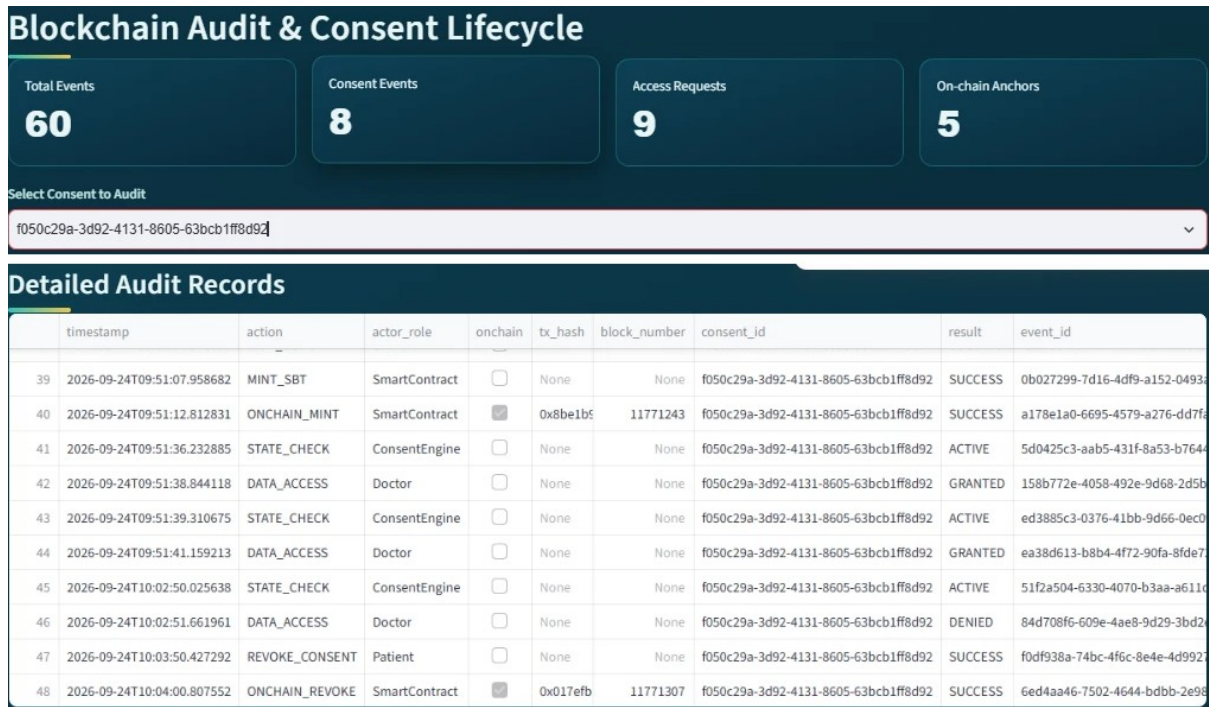
|     | DATE                 | PATIENT                              | ENCOUNTER                            | CATEGORY       | CODE    | DESCRIPTION                      | VALUE    | UNITS   |
|-----|----------------------|--------------------------------------|--------------------------------------|----------------|---------|----------------------------------|----------|---------|
| 238 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8302-2  | Body Height                      | 172.9    | cm      |
| 239 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 72514-3 | Pain severity - 0-10 verbal nume | 0.0      | [score] |
| 240 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 29463-7 | Body Weight                      | 85.1     | kg      |
| 241 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 39156-5 | Body mass index (BMI) [Ratio]    | 28.5     | kg/m2   |
| 242 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8462-4  | Diastolic Blood Pressure         | 80.0     | mm[Hg]  |
| 243 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8480-6  | Systolic Blood Pressure          | 115.0    | mm[Hg]  |
| 244 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8867-4  | Heart rate                       | 88.0     | /min    |
| 245 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 9279-1  | Respiratory rate                 | 13.0     | /min    |
| 246 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | social-history | 72166-2 | Tobacco smoking status           | Never si | None    |
| 247 | 2016-08-12T03:15:24Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | survey         | 76501-6 | Within the last year have you b  | No       | None    |

Download CSV

MEDICATION

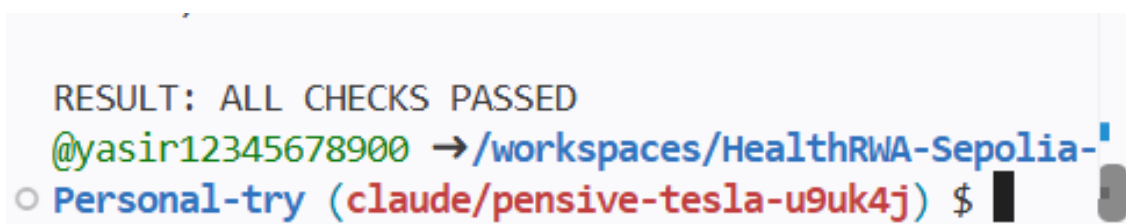
|    | START                | STOP                 | PATIENT                              | PAYER                               | ENCOUNTER                            | CODE    |
|----|----------------------|----------------------|--------------------------------------|-------------------------------------|--------------------------------------|---------|
| 10 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 1049504 |
| 11 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 245134  |
| 12 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 835603  |
| 13 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 1860491 |
| 14 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 1049504 |
| 15 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 245134  |
| 16 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 835603  |
| 17 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 1860491 |
| 18 | 2017-08-18T02:26:12Z | 2018-08-24T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-eba1-0e85ddb2ddbb | 1049504 |

*The doctor subsystem after verification: access granted and the authorised medical records displayed per EMR module; the Observation module's Download CSV control is visible.*



*The auditor subsystem with the evaluated consent selected: aggregate indicators and the Detailed Audit Records, in which the on-chain events carry their transaction hashes and block numbers.*

As shown in the figure above, the system first provides aggregate indicators including: Total Events = 60 Consent Events = 8 Access Requests = 9 On-chain Anchors = 5. These indicators give the auditor an immediate overview of the recorded system activity and of how many events are anchored on the public chain. The five anchors comprise the mint and revocation of the evaluated consent (token #1), the mint of the photographed lifecycle (token #2), and the mint and revocation of an earlier trial consent on the previous contract; the nine access requests comprise the granted, refused and reproduced requests of the two lifecycles together with three granted requests recorded for the earlier trial consents. More importantly, the Consent Lifecycle section reconstructs the sequence of events associated with a particular consent. The reconstructed records include CREATE\_CONSENT performed by the patient, followed by SIGN\_CONSENT performed by each guardian, followed by MINT\_SBT and ONCHAIN\_MINT performed by the smart contract; in the figure the detailed table is scrolled to the on-chain events, whose rows carry the transaction hashes. The subsequent STATE\_CHECK system events demonstrate that the Consent Engine continuously evaluates the state of the authorisation. The doctor then generates DATA\_ACCESS with the result GRANTED, later DATA\_ACCESS with the result DENIED when the jurisdiction check fails, and finally the patient generates REVOKE\_CONSENT followed by ONCHAIN\_REVOKE performed by the smart contract.



*The final verdict of the independent verification: RESULT: ALL CHECKS PASSED.*

As shown in the figure above, the verification was re-executed after the second lifecycle and reports ALL CHECKS PASSED: every recorded transaction was found on Sepolia in its recorded block, and for both tokens on the current contract the revocation state stored by the application matches the state stored by the contract (token #1 revoked, token #2 not revoked). Accordingly, the demonstrated sequence shows that the doctor receives a GRANTED result only while the consent is in the ACTIVE state, and a DENIED or 'not active' result otherwise. This provides an implementation-level demonstration that access decisions are linked to the consent lifecycle rather than being independent application events, and that the recorded lifecycle is consistent with the public chain.

## 12. Publications Summary

- Trust-Centric Consent Framework (Model architecture and multi-party authorisation policies) / Elsevier/IEEE — Status: Almost Ready
- HALAH Prototype & Validation (Decentralised implementation and performance evaluation) / Systems / Security Conference — Status: In Progress
- Formal Security & Lifecycle Analysis (Verification of temporal constraints and state transitions) / Specialized Workshop / Journal — Status: Planned

## 13. Research Plan

The current stage focuses on establishing the foundational trust-oriented authorisation framework. The main activities are the development of the trust-centric consent model, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control. The progression is RO1, RO2, RO3 and then RO4, in which RO1, RO2, and RO3 have been implemented and initially validated through the HALAH prototype. RO4 represents the current transition towards policy-aware access control.

The next stage will build upon the foundational trust-oriented authorisation framework established during current stage and extend the research towards dynamic consent governance, formal security assurance, and comprehensive empirical validation. While current stage focuses on establishing the core mechanisms required to construct a trustworthy authorisation decision, next stage will investigate whether this trust can be maintained over time, formally justified, and reliably demonstrated in practical healthcare data-sharing scenarios.

- Temporal and Lifecycle Trust (Dynamic Consent States): Extend the consent model to incorporate validity periods, dynamic expiration, immediate revocation, and controlled lifecycle transitions. Evaluate access decisions under varying temporal and consent-state constraints. — A robust, dynamic consent management mechanism capable of validating whether an authorisation remains active at the precise point of access.
- Formal Security Assurance (Properties & Verification): Formally define critical security properties and analyse system behaviour under adverse conditions, including invalid identities, insufficient multi-party approvals, policy violations, expired/revoked states, and illegal transitions. — A rigorous formal security

model and verification proof establishing explicit security guarantees for the trust-oriented authorisation framework.

- Comprehensive Empirical Validation (HALAH Prototype Scenarios): Scale and extend HALAH prototype experiments using representative positive and negative healthcare data-sharing scenarios. Measure and compare observed system runtime performance, overhead, and enforcement accuracy. — Empirical evidence and benchmark datasets demonstrating that the implementation consistently and efficiently enforces the proposed authorisation model.
- Integrated Framework Evaluation (Synthesis & End-to-End): Integrate temporal, lifecycle, formal verification, and empirical modules into a unified, cohesive framework. Evaluate cross-component interactions, scalability bottlenecks, and end-to-end feasibility in real-world settings. — A fully integrated, validated Trust Computing framework providing secure, multi-party patient consent and decentralised healthcare data sharing.